DSE 子彈系列– 網上威脅及保安（題解 07）

名字: _____ ( ) Class:_____ 日期: _____

1. 做過的題目（2012–2022） #先認威脅，再講措施

年份	做過的題目	考咩／得分位
2012	未認證 Wi-Fi；藍牙病毒；公鑰／私鑰	Wi-Fi 加密；抗病毒；私鑰解密
2014	以 PKI 把檔案傳往分公司	公鑰加密；私鑰解密；防攔截
2016	GovWiFi 非加密連線；指紋接達控制	截聽風險；指紋較難複製
2017	網站用保安權標核實客戶身分	一次性密碼；限時有效；減低密碼被盜
2018	PKI 能否防止竊聽及資訊阻截	密文不可讀；驗證寄件人及完整性
2021	公眾 Wi-Fi、手機自動鎖及抗病毒軟件	避免敏感交易；減低被盜用及感染風險
2022	流動應用程式的權限及個人資料	只給必要權限；私隱及外洩風險

2. 重點筆記 #威脅、認證、加密，三關都要過

網絡威脅：病毒依附檔案；蠕蟲自行複製並經網絡散播；木馬程式偽裝正常軟件；間諜軟件偷取資料；勒索軟件加密檔案。另有未經授權接達、攔截、仿冒詐騙、濫發郵件及 DoS。

防禦：抗病毒軟件掃描惡意軟件；防火牆按規則過濾網絡流量；更新系統補漏洞；瀏覽器攔截危險網站；無線網絡用 WPA 加密；VPN 建立加密通道，減低公共 Wi-Fi 被截聽的風險。防火牆≠抗病毒軟件。

認證與授權：認證證明「你是誰」，方法包括密碼、生物特徵、智能卡、保安權標及短訊碼；授權決定「你可做甚麼」，依最低權限原則只給所需權限。雙重認證結合兩種方法。

加密：把明文轉成密文，只有正確密碼匙可還原。公鑰加密、私鑰解密可保密；數碼簽署用寄件人私鑰簽署、接收者用寄件人公鑰驗證來源及完整性。PKI＋數碼證書把身分與公鑰綁定；密碼匙越長越安全。

電子交易與私隱：HTTPS／SSL 加密並檢查數碼證書；用短訊碼或保安權標認證；避免在公共電腦或未加密 Wi-Fi 交易；交易後登出。應用程式只給必要權限；收集個人資料須說明用途並加密。

答題用 C-F-B：場景（C）＋保安特性（F）＋好處（B）。例：網上銀行用 HTTPS（C），SSL 加密交易資料（F），被攔截亦不能讀取（B）。

*失分位：只寫「加密」而沒說明用哪條密碼匙；混淆認證與授權；以為 HTTPS 代表網站可信；把防火牆當抗病毒軟件；只寫「小心」。

3. 類似題 #換個場景，同一角度

1. 小美在咖啡店連接一個沒有密碼的公共 Wi-Fi，並準備登入網上銀行。

(a) 指出**兩個**使用該 Wi-Fi 進行網上交易的風險。

【答案】公共 Wi-Fi 未加密，交易資料可能被截聽；攻擊者可設假冒熱點騙取銀行密碼或短訊驗證碼；同一網絡的裝置亦可能傳播惡意軟件。

(b) 建議**兩個**減低風險的方法。

【答案】改用流動數據或 VPN；確認網址為 HTTPS 並檢查數碼證書；避免在公共 Wi-Fi 進行敏感交易；啟用雙重認證，交易後登出。

2. 家輝收到銀行電郵，附件名為「帳戶異常.pdf.exe」，要求立即登入及更新資料。

(a) 指出這是哪一類網絡威脅，並解釋**兩個**可疑之處。

【答案】仿冒詐騙（釣魚）。寄件人假扮銀行並製造緊急語氣；附件用雙副檔名「.pdf.exe」掩飾可執行檔，可能是木馬程式或勒索軟件；連結亦可能導向假網站騙取帳戶資料。

(b) 建議**三個**保安措施。

【答案】不要開啟附件或點擊連結；經銀行官方網站或熱線核實；用抗電腦病毒軟件掃描；更新系統及軟件；備份重要檔案；把郵件標示為濫發郵件。

3. 學校經互聯網把含學生資料的檔案由總校傳到分校，並採用 PKI。

(a) 簡述公開密碼匙及私人密碼匙在此傳送中的用途。

【答案】寄件人用分校的公開密碼匙加密檔案；只有分校的私人密碼匙可解密，確保機密；寄件人另用自己的私人密碼匙產生數碼簽署，分校用寄件人的公開密碼匙驗證來源及完整性。

(b) 解釋數碼證書如何協助分校確認寄件人身分。

【答案】數碼證書由受信任的簽發機構發出，把寄件人身分與其公開密碼匙綁定；分校驗證證書及數碼簽署，若兩者有效，便可確認寄件人身分，亦證明檔案未被篡改。